

ANÁLISIS DE RIESGOS

G3 Project · AR_G3

02/05/2026

CONFIDENCIAL

1. Introducción

Este documento tiene el propósito de ser anexado a la documentación de seguridad de la organización sobre la que se ha generado, con el objetivo de conseguir la aprobación o autorización de la autoridad responsable.

Datos administrativos

Organización: IES Rafael Alberti

Descripción: Empresa-G3

Autor: Grupo 3

Versión: 1.0

Fecha: 27/04/2026

Responsable del Sistema: David

Responsable de la Seguridad de la Información: Abel

Reportero: Jose

Dimensiones de valoración

- [D] Disponibilidad
- [I] Integridad de los datos
- [C] Confidencialidad de los datos
- [A] Autenticidad de los usuarios y de la información
- [T] Trazabilidad del servicio y de los datos
- [DP] Datos personales

2. Activos

Relación de activos identificados en el sistema de información.

Dominio de seguridad: [base] SERV_AD

Los activos están organizados en capas:

Código	Nombre	Explicación
C01	Información	Capa más alta
C02	Servicios	Servicios Web, Cloud
C03	Software y Aplicaciones	Procesa y almacena la información (CRM/ERP, Backups)
C04	Servidores y Hardware	Ejecuta el software (Archivos, Correos, Equipos)
C05	Red e Infraestructura	Capa más baja: conecta todo lo demás

Información y servicios esenciales

- ▶ [C02] Servicios
 - [ID-0009] Página Web
- ▶ [C01] Información
 - [ID-0001] Datos Personales
 - [ID-0002] Información del cliente y Proveedores

Activos de soporte

- ▶ [C05] Red e Infraestructura
 - [ID-0006] Red Corporativa
- ▶ [C04] Servidores y Hardware
 - [ID-0003] Servidor de Archivos
 - [ID-0004] Servidor de Correos
 - [ID-0005] Equipos de Usuario
- ▶ [C03] Software y Aplicaciones
 - [ID-0008] Aplicaciones CRM/ERP
 - [ID-0007] Sistema de Backups

3. Descripción de los Activos

| [ID-0006] Red Corporativa

Dominio de seguridad: [base] SERV_AD

Clases de activos:

- ▶ [COM] Redes de comunicaciones
- ▶ [COM.wifi] WiFi

| [ID-0003] Servidor de Archivos

Dominio de seguridad: [base] SERV_AD

Clases de activos:

- ▶ [HW] Equipamiento informático (hardware)
- ▶ [HW.data] que almacena datos

| [ID-0004] Servidor de Correos

Dominio de seguridad: [base] SERV_AD

Clases de activos:

- ▶ [HW] Equipamiento informático (hardware)
- ▶ [HW.vhost] equipos virtuales (máquinas virtuales)

| [ID-0005] Equipos de Usuario

Dominio de seguridad: [base] SERV_AD

Clases de activos:

- ▶ [HW] Equipamiento informático (hardware)
- ▶ [HW.pc] informática personal

| [ID-0009] Página Web

Dominio de seguridad: [base] SERV_AD

Clases de activos:

- ▶ [essential] Información y servicios esenciales
- ▶ [essential.service.operations] operaciones
- ▶ [S] Servicios
- ▶ [S.client.www] navegación web

| [ID-0010] Servicios en la Nube

Dominio de seguridad: [base] SERV_AD

Clases de activos:

- ▶ [S] Servicios
- ▶ [S.prov.cloud.PaaS] Plataforma como servicio

| [ID-0008] Aplicaciones CRM/ERP

Dominio de seguridad: [base] SERV_AD

Clases de activos:

- ▶ [SW] Aplicaciones (software)
- ▶ [SW.sub] desarrollo a medida (subcontratado)

| [ID-0007] Sistema de Backups

Dominio de seguridad: [base] SERV_AD

Clases de activos:

- ▶ [HW] Equipamiento informático (hardware)
- ▶ [HW.backup] equipamiento de respaldo
- ▶ [Media] Soportes de información
- ▶ [Media.electronic.edisk] disco cifrado

| [ID-0001] Datos Personales

Dominio de seguridad: [base] SERV_AD

Clases de activos:

- ▶ [essential] Información y servicios esenciales
- ▶ [essential.info.per.normal.1] datos de carácter identificativo (nombre y apellidos, NIF/DNI, dirección postal, email, teléfono, ...)
- ▶ [essential.info.per.normal.2] características personales (estado civil, fecha y lugar de nacimiento, edad, sexo, nacionalidad, ...)
- ▶ [essential.info.per.normal.3] datos académicos
- ▶ [essential.info.per.normal.4] datos profesionales
- ▶ [essential.info.per.normal.5] datos bancarios

| [ID-0002] Información del cliente y Proveedores

Dominio de seguridad: [base] SERV_AD

Clases de activos:

- ▶ [essential] Información y servicios esenciales
- ▶ [essential.info.biz] datos de interés para el negocio
- ▶ [essential.info.com] datos de interés comercial
- ▶ [essential.info.per.normal.1] datos de carácter identificativo (nombre y apellidos, NIF/DNI, dirección postal, email, teléfono, ...)
- ▶ [essential.info.per.normal.2] características personales (estado civil, fecha y lugar de nacimiento, edad, sexo, nacionalidad, ...)
- ▶ [essential.info.per.normal.5] datos bancarios

4. Valoración de los Activos

Leyenda:

NOTA	VALORACIÓN
A+	Muy alto
A	Alto
M	Medio
B	Bajo

Capa [C05] Red e Infraestructura

Activo	[D]	[I]	[C]	[A]	[T]	[DP]
[ID-0006] Red Corporativa	A+	A	A	A	M	

Explicación:

- (D) Sin red no funciona ningún sistema
- (I) Tráfico manipulado permite ataques MITM con consecuencias muy graves
- (A) Todo el tráfico corporativo, incluidos datos personales, circula por ella
- (T) Control de acceso a la red mediante VLANs y autenticación 802.1x

Capa [C04] Servidores y Hardware

Activo	[D]	[I]	[C]	[A]	[T]	[DP]
[ID-0003] Servidor de Archivos	A	A	A	A	M	
[ID-0004] Servidor de Correos	M	M	A	M	M	
[ID-0005] Equipos de Usuario	M	B	M	M	B	

Explicación:

[ID-0003] Servidor de Archivos

- (D) Su caída afecta directamente al CRM/ERP y deja sin acceso a ficheros corporativos
- (I) Ficheros corrompidos en el servidor central implican pérdida de información crítica
- (C) Aloja documentos sensibles de clientes, contratos y datos operativos
- (A) El control de acceso a ficheros debe ser estricto para evitar accesos no autorizados

(T) Logs de acceso a ficheros disponibles; nivel medio suficiente

[ID-0004] Servidor de Correos

(D) El correo tolera interrupciones breves sin paralizar el negocio completamente

(I) La alteración de mensajes es importante pero el impacto en la org. es moderado

(C) Los correos pueden contener datos personales, acuerdos comerciales y credenciales

(A) Mecanismos SPF/DKIM protegen contra spoofing a nivel estándar

(T) Logs de envío y recepción estándar del servidor de correo

[ID-0005] Equipos de Usuario

(D) Un equipo individual caído no paraliza la organización; hay sustitutos

(I) Los datos locales tienen bajo valor corporativo; lo crítico está en servidores

(C) Pueden cachear credenciales, documentos y sesiones activas del CRM

(A) Autenticación de usuarios en el dominio corporativo con contraseña o MFA

(T) Logs básicos del sistema operativo; trazabilidad limitada

Capa [C03] Software y Aplicaciones

Activo	[D]	[I]	[C]	[A]	[T]	[DP]
[ID-0008] Aplicaciones CRM/ERP	A	A+	10	A	A	
[ID-0007] Sistema de Backups	A	A	A	M	M	

Explicación:

[ID-0008] Aplicaciones CRM/ERP

(D) Toda la operativa comercial y de gestión depende del funcionamiento del ERP

(I) Datos de gestión corrompidos llevan a decisiones erróneas e incumplimiento RGPD

(C) Concentra datos personales y comerciales; su exposición es la brecha más grave posible

(A) Control de roles y permisos por usuario es crítico para evitar fraude interno

(T) Auditoría de operaciones obligatoria por RGPD y requisitos de compliance

[ID-0007] Sistema de Backups

(D) Sin backups disponibles no es posible recuperarse ante ningún incidente grave

(I) Un backup corrupto equivale a no tener backup; pérdida total de datos

(C) Contiene copia completa de todos los datos sensibles de la organización

(A) Verificar que las copias son legítimas y no han sido manipuladas por atacante

(T) Registro del resultado y hora de ejecución de cada copia de seguridad

Capa [C02] Servicios

Activo	[D]	[I]	[C]	[A]	[T]	[DP]
[ID-0009] Página Web	A	M	B	M	B	
[ID-0010] Servicios en la Nube	A	M	A	M	M	

Explicación:

[ID-0009] Página Web

(D) Caída prolongada implica pérdida de ventas online e impacto negativo en imagen

(I) Defacement o alteración de contenido daña la reputación de la empresa. Incumplimiento de una obligación contractual

(C) El contenido es público por naturaleza; baja necesidad de confidencialidad

(A) Verificar autenticidad de transacciones y formularios de contacto

(T) Logs básicos de acceso web (Apache/Nginx); trazabilidad limitada

[ID-0010] Servicios en la Nube

- (D) El SLA del proveedor cloud es crítico; su caída afecta a web y correo simultáneamente
- (I) Datos en tránsito protegidos con TLS; riesgo moderado de manipulación
- (C) Datos pueden residir fuera del perímetro corporativo en servidores del proveedor
- (A) Autenticación de servicios cloud; se recomienda MFA en todas las cuentas
- (T) Logs de acceso del proveedor cloud disponibles bajo petición o dashboard

Capa [C01] Información

Activo	[D]	[I]	[C]	[A]	[T]	[DP]
[ID-0001] Datos Personales	A	A+	A+	A	A	
[ID-0002] Información del cliente y Proveedores	A	A	A+	A	M	

Explicación:

[ID-0001] Datos Personales

- (D) Si los datos personales no están disponibles, los empleados y asesores no pueden acceder a los datos de los clientes y la actividad de la empresa se detiene
- (I) Datos contables y personales. Alterarlo tiene impacto legal grave
- (C) RGPD activo, brecha = sanción, más pérdida de confianza
- (A) Datos falsos comprometen decisiones legales y contables
- (T) Es necesario auditar quién accede a datos personales

[ID-0002] Información del cliente y Proveedores

- (D) Sin contrato/facturas no se puede operar
- (I) Facturas o contratos alterados = fraude
- (C) Datos comerciales sensibles, ventaja competitiva
- (A) Los documentos deben ser verificables
- (T) Útil, pero no crítico

5. Riesgo Acumulado

Se presentan los principales riesgos en cada dominio de seguridad del sistema en las diferentes fases de trabajo.

Amenaza: Presenta la amenaza dentro del catálogo de PILAR. Una amenaza aparece cuando algún activo del sistema está expuesto a ella.

D: dimensión: Se muestra la dimensión (o dimensiones) de seguridad a las que afecta la amenaza.

I: impacto: Se muestra el máximo impacto causado por esta amenaza en algún activo del sistema.

R: riesgo: Se muestra el máximo riesgo al que está expuesto el sistema por causa de esta amenaza.

Fase: [current] situación actual

[base] SERV_AD

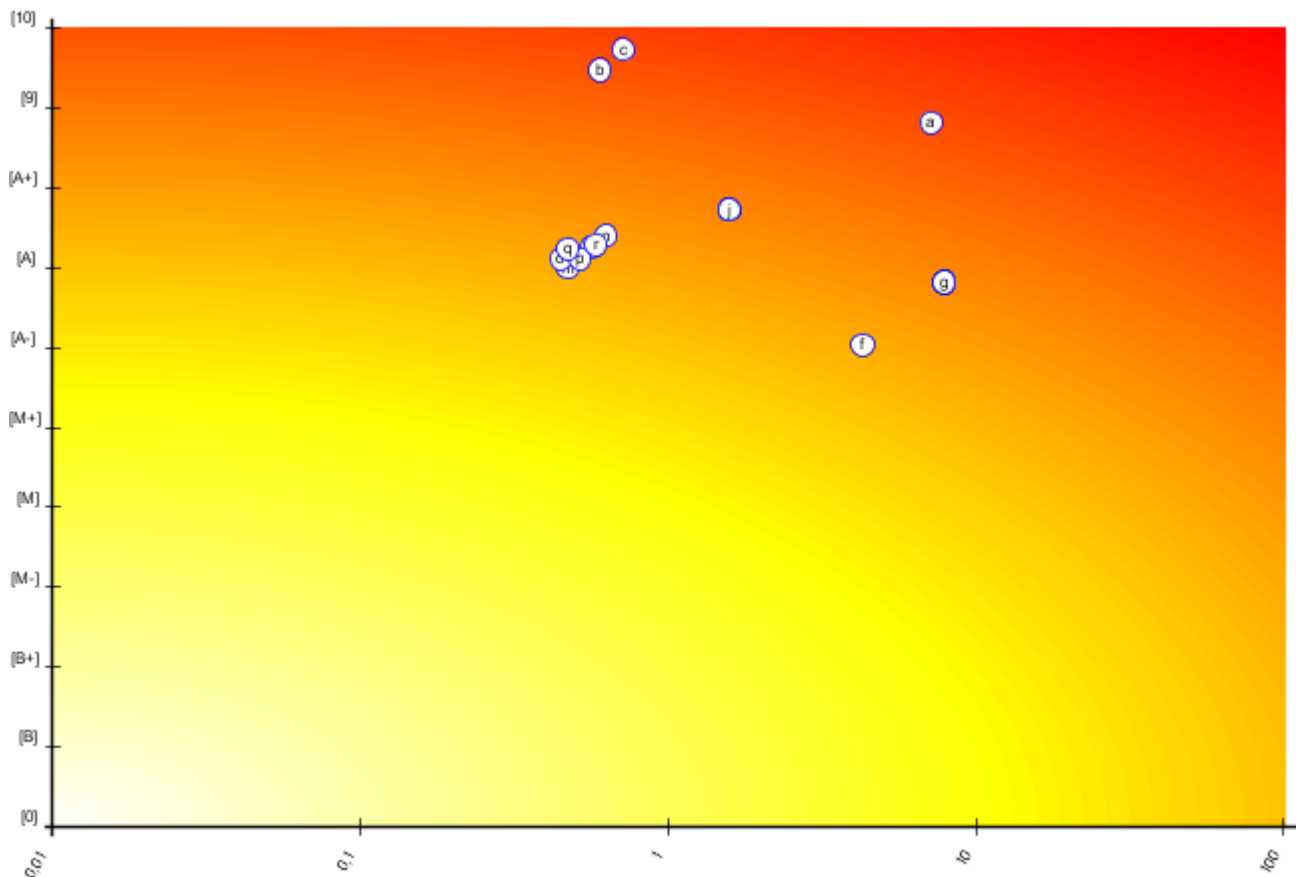
Amenaza	D	I	R
[E.21] Errores de mantenimiento / actualización de programas (software)	C	[9]	{6,9}
[A.22] Manipulación de programas	I, C	[10]	{6,5}
[A.8] Difusión de software dañino	D, I, C	[9]	{6,3}

Amenaza	D	I	R
[A.24] Denegación de servicio	D	[A+]	{5,7}
[E.24] Caída del sistema por agotamiento de recursos	D	[A]	{5,7}
[I.6] Corte del suministro eléctrico	D	[A+]	{5,3}
[E.20] Vulnerabilidades de los programas (software)	C	[A+]	{5,3}
[X.2] Phishing	C	[A]	{5,1}
[I.10] Degradación de los soportes de almacenamiento de la información	D	[A]	{5,1}

Evolución del riesgo

Se presentan los principales pares activo-amenaza identificados en la situación actual. Las dimensiones afectadas son **D (Disponibilidad)**, **I (Integridad)** y **C (Confidencialidad)**.

Activo	Amenaza	Dimensión	Interpretación
[ID-0008] CRM/ERP	[E.21] Errores mantenim. SW	C	El CRM puede verse comprometido en confidencialidad por actualizaciones mal hechas
[ID-0008] CRM/ERP	[A.8] Software dañino	D, C	Malware que afecta disponibilidad y confidencialidad del ERP
[ID-0008] CRM/ERP	[A.22] Manipulación programas	I, C	Modificación maliciosa del CRM — integridad y confidencialidad
[ID-0007] Backups	[E.24] Caída por recursos	D	Los backups fallan por falta de espacio/RAM > pérdida de disponibilidad
[ID-0004] Correos	[E.24] Caída por recursos	D	Servidor de correo caído por agotamiento de recursos
[ID-0006] Red Corp.	[A.24] Denegación servicio	D	DDoS o flood que tumba la red corporativa
Equipos/Backups	[E.24 / A.24]	D	Indisponibilidad por recursos o ataque en múltiples activos
[ID-0007] Backups	[I.10] Degrad. soportes	D	Los discos de backup se degradan. Riesgo de pérdida total de datos
[ID-0007] Backups	[E.23] Errores manten. HW	D	Mantenimiento incorrecto daña los soportes de backup
[ID-0007] Backups	[I.6] Corte eléctrico	D	Corte de luz durante proceso de backup > corrupción



- a. C: ID-0008 * E.21
- b. D, C: ID-0008 * A.8
- c. I, C: ID-0008 * A.22
- d. D: ID-0007 * E.24
- e. D: ID-0004 * E.24
- f. D: ID-0006 * A.24
- g. D: ID-0005 * E.24
- h. D: ID-0004 * A.24
- i. D: ID-0007 * A.24
- j. D: ID-0005 * A.24
- k. D: ID-0005 * I.7
- l. D: ID-0005 * A.26
- m. D: ID-0007 * I.7
- n. D: ID-0007 * I.10
- o. D: ID-0007 * E.23
- p. D: ID-0007 * A.25
- q. D: ID-0007 * A.18
- r. D: ID-0007 * I.6

6. Riesgo Repercutido

Se presentan los máximos riesgos a los que están expuestos los activos esenciales del sistema en cada fase de trabajo.

Activo: Presenta el activo esencial que está en riesgo; es decir, sobre el que repercute indirectamente la amenaza.

Amenaza: Presenta la amenaza dentro del catálogo de PILAR.

D: dimensión: Se muestra la dimensión (o dimensiones) de seguridad a las que afecta la amenaza.

I: impacto: Se muestra el máximo impacto causado por esta amenaza sobre el activo esencial.

R: riesgo: Se muestra el máximo riesgo al que está expuesto el activo esencial por causa de esta amenaza.

Activo	Amenaza	D	I	R
[ID-0008] CRM/ERP	[E.21] Errores de mantenimiento / actualización de programas (software)	C	[9]	{6,9}
[ID-0008] CRM/ERP	[A.22] Manipulación de programas	C	[10]	{6,5}
[ID-0008] CRM/ERP	[A.8] Difusión de software dañino	C	[9]	{6,3}
[ID-0006] Red Corp.	[A.24] Denegación de servicio	D	[A+]	{5,7}
[ID-0006] Red Corp.	[E.24] Caída del sistema por agotamiento de recursos	D	[A]	{5,7}
[ID-0004] Serv. Correos	[A.24] Denegación de servicio	D	[A+]	{5,7}
[ID-0004] Serv. Correos	[E.24] Caída del sistema por agotamiento de recursos	D	[A]	{5,7}
[ID-0005] Equipos Usr.	[A.24] Denegación de servicio	D	[A+]	{5,7}
[ID-0005] Equipos Usr.	[E.24] Caída del sistema por agotamiento de recursos	D	[A]	{5,7}
[ID-0007] Backups	[E.24] Caída del sistema por agotamiento de recursos	D	[A]	{5,7}
[ID-0007] Backups	[A.24] Denegación de servicio	D	[A+]	{5,7}

7. Buenas prácticas

Aquí se presentan la priorización de medidas técnicas y los principios de economía circular aplicados:

Medidas técnicas priorizadas

A partir del análisis de riesgo acumulado y repercutido, las medidas se priorizan según riesgo identificado, atendiendo primero a los activos con mayor impacto en la organización.

Prioridad 1: Riesgo Crítico ($R \geq 6,5$)

Activos afectados: [ID-0008] CRM/ERP

Amenaza	Medida Técnica
[E.21] Errores de mantenimiento/actualización SW	Política de gestión de parches con entorno de pruebas previo a producción; freeze de versiones en producción
[A.22] Manipulación de programas	Control de integridad de binarios (hash SHA-256); despliegue firmado; revisión de cambios en código subcontratado
[A.8] Difusión de software dañino	EDR/Antimalware en servidores de aplicaciones; escaneo de dependencias (SAST/DAST); política de software autorizado

Prioridad 2: Riesgo Alto (R 5,3–5,7)

Activos afectados: [ID-0006] Red Corporativa, [ID-0004] Servidor Correos, [ID-0005] Equipos Usuario, [ID-0007] Sistema de Backups

Amenaza	Medida Técnica
[A.24] Denegación de servicio	Implementación de IDS/IPS (Suricata/Snort), rate limiting en red, segmentación con VLANs
[E.24] Agotamiento de recursos	Monitorización con alertas de umbrales (CPU/RAM/disco) en SIEM (Wazuh/ELK); capacidad de escalado
[I.6] Corte suministro eléctrico	SAI/UPS en servidores críticos; generador como contingencia
[E.20] Vulnerabilidades de software	Análisis periódico con OpenVAS/Nessus; gestión de CVEs con SLA de remediación definido
[X.2] Phishing	Filtro antiphishing en servidor de correos (SPF, DKIM, DMARC); formación al personal
[I.10] Degradación de soportes	Pruebas periódicas de restauración de backup; rotación de soportes y uso de discos cifrados

Principios de Economía Circular aplicados

La **Economía Circular** implica reducir residuos tecnológicos, extender la vida útil de los activos y minimizar el consumo de recursos. Las siguientes medidas del plan integran estos principios:

- **Reutilización de hardware:** antes de reemplazar ID-0005 - Equipos de Usuario, valorar actualización de RAM o SSD para extender ciclo de vida.
- **Virtualización y consolidación:** el ID-0004 - Servidor de Correos ya está categorizado como [HW.vhost]; consolidar más servicios en máquinas virtuales reduce el consumo energético y el hardware físico necesario.
- **Backups en disco cifrado:** los discos cifrados reutilizables tienen menor huella ambiental que soportes ópticos o cintas de un solo ciclo.
- **Cloud como servicio:** el modelo PaaS reduce infraestructura propia, optimizando el consumo de recursos compartido entre múltiples clientes del proveedor.
- **Política de borrado seguro:** al dar de baja equipos, aplicar borrado certificado (NIST 800-88) para permitir reutilización o reciclaje responsable, cumpliendo también con RGPD en la gestión de ID-0001 - Datos Personales.

Plan de Acción en Ciberseguridad

El plan se estructura en tres horizontes temporales con medidas concretas, responsables y criterios de éxito, siguiendo el ciclo de mejora continua del NIST CSF.

Corto Plazo (0–3 meses)

#	Acción	Activo Objetivo	Responsable	Criterio de Éxito
1	Activar DMARC, DKIM y SPF en el servidor de correos	ID-0004	Abel (RSI)	0 dominios sin política DMARC
2	Implementar MFA en todas las cuentas de acceso al CRM/ERP	ID-0008	Abel (RSI)	100% usuarios con 2FA activo

#	Acción	Activo Objetivo	Responsable	Criterio de Éxito
3	Configurar alertas de monitorización de recursos en SIEM	ID-0007, ID-0004, ID-0006	Abel (RSI)	Alertas activas con umbral $\geq 80\%$
4	Establecer política de contraseñas robusta en dominio corporativo	ID-0005	David (RS)	GPO aplicada y auditada
5	Verificar y probar restauración del Sistema de Backups	ID-0007	David (RS)	Restauración exitosa documentada

Medio Plazo (3–9 meses)

#	Acción	Activo Objetivo	Responsable	Criterio de Éxito
6	Desplegar IDS/IPS (Suricata) en la red corporativa	ID-0006	Abel (RSI)	Ruleset activo, alertas correladas en SIEM
7	Realizar análisis de vulnerabilidades con Nessus/OpenVAS	Todos	Abel (RSI)	Informe de vulnerabilidades + plan de remediación
8	Implantación de VLANs para segmentación (LAN, DMZ, Servidores)	ID-0006	David (RS)	Tráfico segmentado verificado con Wireshark
9	Formación en phishing y concienciación al personal	ID-0005	Josema (Reportero)	Test phishing simulado con tasa de clic $< 10\%$
10	Revisar y actualizar el CRM/ERP en entorno de pruebas previo	ID-0008	Abel (RSI)	Pipeline de actualización documentado y probado

Largo Plazo (9–18 meses)

#	Acción	Activo Objetivo	Responsable	Criterio de Éxito
11	Elaborar y probar el Plan de Respuesta a Incidentes (IR Plan)	Todos	Abel + David	Simulacro ejecutado y lecciones recogidas
12	Implementar política de borrado seguro en equipos de baja	ID-0005	David (RS)	Certificados de borrado archivados
13	Auditoría externa de seguridad y revisión del análisis de riesgos	Todos	David (RS)	Informe de auditoría + cierre de hallazgos
14	Ampliar cobertura de backup con 3-2-1 (3 copias, 2 soportes, 1 offsite)	ID-0007	Abel (RSI)	Copia offsite verificada mensualmente

#	Acción	Activo Objetivo	Responsabl e	Criterio de Éxito
15	Revisión periódica de accesos y privilegios en CRM/ERP y Servidor de Archivos	ID-0003, ID-0008	Abel (RSI)	Access review trimestral documentado

Seguimiento y Mejora Continua

El plan debe revisarse al menos trimestralmente, actualizando las amenazas del catálogo PILAR conforme evolucione la superficie de ataque. Los indicadores clave de seguimiento son:

- Número de vulnerabilidades críticas abiertas (objetivo: 0 sin plan de remediación)
- Tiempo medio de detección y respuesta a incidentes (MTTD/MTTR)
- Porcentaje de controles del NIST CSF implementados vs. objetivo
- Resultado de simulacros de restauración de backups